

SIMATS ENGINEERING
ASSESSMENT TOOL II – INDUSTRY PROBLEM TASK

COURSE OUTCOME COVERED

CO5: Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)

Instructions: Answer all questions. Each question carries 20 marks.

1. A mid-sized financial organization operates a Windows domain network consisting of 150 interconnected systems. During a security incident investigation, it is observed that attackers have exploited NULL sessions, open RPC services, and misconfigured shared folders to gain unauthorized access. Initial analysis indicates that 45% of systems allow anonymous enumeration, and among those, 60% are susceptible to SMB-based lateral movement attacks. Furthermore, each compromised system can attempt to access 3 additional systems, with a success probability of 0.3 per attempt.

Question:

Analyze the extent of the attack by calculating the number of systems compromised during the initial stage of exploitation. Further, estimate the spread of the attack in the second stage due to lateral movement. Based on your analysis, evaluate whether the network is at risk of a large-scale compromise (greater than 70% of total systems), and justify which vulnerability (NULL sessions, RPC exposure, or weak shares) should be prioritized for immediate mitigation.

Given Data

- Total systems = 150
- Systems allowing anonymous enumeration = 45%
- Susceptible to SMB lateral movement = 60%
- Additional systems attempted per compromised system = 3
- Success probability per attempt = 0.3

Step 1: Initial Systems Exposed

Therefore, approximately 68 systems allow anonymous enumeration.

Step 2: Initially Compromised Systems

Of these, 60% are susceptible:

Expected initial compromised systems:

Step 3: Second-Stage Lateral Movement

Each compromised system attempts to access 3 additional systems.

With a success probability of 0.3:

Expected second-stage compromises:

Step 4: Total Expected Compromise

Approximately:

Percentage of network compromised:

Risk Evaluation

70% of the network is:

Expected compromise = 76.95 systems, which is below 105 systems.

Therefore, based on the given probabilities, the attack is not expected to exceed 70% of the network in the second stage.

Priority Vulnerability

NULL sessions should be prioritized first because they allow anonymous enumeration and provide attackers with information about users, shares, and systems. Since anonymous enumeration is the starting point for the subsequent SMB attack path, eliminating NULL sessions can reduce the initial attack surface.

Final Answer

Initial compromise = 40.5 systems

Second-stage compromise = 36.45 systems

Total expected compromise = $76.95 \approx 77$ systems

Network affected = 51.3%

70% threshold = 105 systems

Large-scale compromise >70% = No

2. An enterprise network consists of 120 systems, out of which 70 systems expose RPC services to the internal network. A vulnerability scan reveals that 40% of these systems are susceptible to known exploits, and the probability of successful exploitation for each vulnerable system is 0.5. However, each exploitation attempt carries a detection probability of 0.25 due to intrusion detection systems deployed within the network.

Question:

Determine the expected number of systems that can be successfully compromised by an attacker. Additionally, compute the expected number of detection alerts generated during the exploitation process. Based on your results, critically evaluate whether an attacker aiming to remain stealthy would proceed with exploitation or adopt alternative attack strategies, providing justification for your reasoning.

Given Data

- Total systems = 120
- Systems exposing RPC = 70
- Vulnerable RPC systems = 40%
- Exploitation success probability = 0.5
- Detection probability = 0.25

Step 1: Vulnerable Systems

Therefore, 28 systems are vulnerable.

Step 2: Successfully Compromised Systems

Expected successful compromises:

Step 3: Expected Detection Alerts

There are 28 exploitation attempts, with a detection probability of 0.25.

Expected detection alerts:

Step 4: Stealth Evaluation

The attacker has an expected:

- 14 successful compromises
- 7 detection alerts

This means there is a significant probability of detection during exploitation. An attacker whose primary objective is stealth would therefore be unlikely to repeatedly exploit all vulnerable RPC services using the same approach.

A stealth-oriented attacker would instead seek approaches that generate fewer detectable events and would minimize noisy exploitation activity.

Final Answer

Vulnerable systems = 28

Expected successful compromises = 14

Expected detection alerts = 7

Conclusion

The network presents a significant risk because 14 systems could potentially be compromised. However, the 25% detection probability makes repeated exploitation relatively noisy. A stealth-focused attacker would therefore prefer less detectable approaches rather than aggressively exploiting every vulnerable RPC system.

3. A cloud-hosted Linux server is running multiple services exposed to the internet. Security analysis identifies four critical services, with independent probabilities of vulnerability being 0.3, 0.2, 0.25, and 0.15, respectively. It is also observed that the system has weak file permissions, which can be exploited with a probability of 0.5 once initial access is gained.

Question:

Evaluate the probability that at least one service is vulnerable and can be exploited by an attacker. Further, compute the overall probability of a full system compromise, considering both service exploitation and privilege escalation through weak permissions. Based on your findings, analyze whether strengthening file permissions alone would significantly reduce the overall risk, and justify your conclusion.

Given Data

Four critical services have vulnerability probabilities:

- Service 1 = 0.3
- Service 2 = 0.2
- Service 3 = 0.25
- Service 4 = 0.15

Probability of privilege escalation through weak permissions = 0.5

Step 1: Probability That No Service Is Vulnerable

Step 2: Probability That At Least One Service Is Vulnerable

Therefore:

There is a 64.3% probability that at least one exposed service is vulnerable.

Step 3: Probability of Full System Compromise

For full compromise, assume that privilege escalation is required after initial service exploitation.

Therefore:

Step 4: Evaluation

Strengthening file permissions reduces the privilege-escalation probability and therefore reduces the probability of full system compromise.

However, file-permission hardening alone is not sufficient, because there remains a 64.3% probability of at least one vulnerable service.

Final Answer

Probability of at least one vulnerable service = 64.3%

Probability of full compromise = 32.15%

Conclusion

The server has significant exposure because multiple internet-facing services create several possible entry points. File-permission hardening is important, but it must be combined with patch management, service hardening, firewall restrictions, vulnerability scanning, and least-privilege controls.

4. An organization uses Network File System (NFS) to share resources across three internal subnets. Due to improper configuration, unauthorized access probabilities from these subnets are estimated as 0.4, 0.3, and 0.2, respectively. Once access to the NFS share is obtained, the probability of privilege escalation to root access is 0.7.

Question:

Calculate the probability that at least one subnet successfully gains unauthorized access to the NFS share. Subsequently, determine the overall probability of a complete system compromise. Based on your analysis, evaluate the effectiveness of restricting NFS access to a single subnet as a mitigation strategy, and justify your recommendation.

Given Data

Unauthorized-access probabilities:

- Subnet 1 = 0.4
- Subnet 2 = 0.3
- Subnet 3 = 0.2
- Privilege escalation probability = 0.7

Step 1: Probability That No Subnet Gains Access

Step 2: Probability That at Least One Subnet Gains Unauthorized Access

Therefore:

Step 3: Probability of Complete Compromise

Once unauthorized access is obtained, privilege escalation has a probability of 0.7.

Therefore:

Step 4: Restricting NFS Access

If NFS access is restricted to only one subnet, the safest choice is the subnet with the lowest unauthorized-access probability:

Probability of complete compromise:

Reduction:

Final Answer

Probability of unauthorized NFS access = 66.4%

Probability of complete compromise = 46.48%

If restricted to the lowest-risk subnet:

Complete compromise probability = 14%

Conclusion

Restricting NFS access to a single, trusted subnet can significantly reduce the attack surface. However, it should be combined with strong authentication, proper NFS configuration, least privilege, firewall rules, and root-access restrictions.

5. An e-commerce platform maintains a database containing 50,000 user records, of which 30% are classified as sensitive. A successful SQL injection attack allows data extraction at a rate of 500 records per second. However, the application firewall detects and blocks the attack after 40 seconds.

Question:

Compute the total number of records that can be extracted before the attack is blocked. Determine the percentage of total data compromised, and estimate the number of sensitive

records exposed. Based on your analysis, evaluate the severity of the breach and justify whether the existing detection mechanism is sufficient to protect critical data.

Given Data

- Total database records = 50,000
- Sensitive records = 30%
- Extraction rate = 500 records/second
- Detection time = 40 seconds

Step 1: Records Extracted

Therefore:

can be extracted before the attack is blocked.

Step 2: Percentage of Total Data Compromised

Therefore:

of the database could be compromised.

Step 3: Sensitive Records Exposed

Sensitive records represent 30% of the extracted records:

Therefore:

could be exposed.

Step 4: Severity Assessment

The breach should be classified as HIGH to CRITICAL because:

- 20,000 records can be extracted.
- 40% of the database is exposed.
- Approximately 6,000 sensitive records may be compromised.
- SQL injection can directly affect database confidentiality.
- Customer information may be exposed on a large scale.

Step 5: Is the Detection Mechanism Sufficient?

No.

Although the application firewall detects and blocks the attack after 40 seconds, an attacker can still extract 20,000 records before detection.

The detection mechanism therefore reduces the duration of the attack but does not adequately protect critical data.

Recommended Measures

1. Use parameterized SQL queries.

2. Implement strict input validation.
3. Apply database least privilege.
4. Deploy a properly configured WAF.
5. Implement database activity monitoring.
6. Detect abnormal query rates earlier.
7. Restrict database access from the application layer.
8. Encrypt sensitive information.

Final Answer

Records extracted = 20,000

Percentage compromised = 40%

Sensitive records exposed = 6,000

Severity = High/Critical

Conclusion

The existing detection mechanism is insufficient because a large amount of data can be extracted within only 40 seconds. Preventive controls such as parameterized queries and least-privilege database access are more important than relying only on post-attack detection.

Code of Conduct:

I **SURU SAI KEERTHI[192424368]** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: